TD noté: rapport d'audit au RSSI

M1 Informatique: Sécurité

Novembre 2024

1 Mise en situation

Vous êtes consultant dans l'entreprise Bêta, société de services qui place ses experts en cybersécurité au sein d'entreprises clientes pour les aider à améliorer la sécurité de leur système d'information. Vous êtes actuellement en mission avec votre équipe au sein du groupe publicitaire Gamma pour y réaliser un audit de sécurité.

Une autre équipe de Bêta a d'abord effectué un audit de vulnérabilités, qui a permis de révéler un certain nombre de failles affectant le système d'information de Gamma. Dans le cadre de votre mission, vous êtes chargés par le RSSI de Gamma d'étudier ces vulnérabilités et leur impact potentiel sur le SI. L'architecture du SI est décrite dans la section 5.

2 Énoncé

Une vulnérabilité particulière sera attribuée à chaque groupe. Le RSSI attend de vous une présentation orale durant entre cinq et dix minutes. Celle-ci devra notamment répondre aux questions suivantes:

- Quel composant du système d'information est impacté par cette vulnérabilité?
- En quoi consiste exactement la vulnérabilité?
- Comment résoudre cette vulnérabilité?

Pour illustrer l'impact que peut avoir la vulnérabilité, vous mettrez en place un scénario d'attaque cohérent basé sur l'exploitation de ladite vulnérabilité. Il est recommandé d'utiliser le modèle de la kill chain de Lokheed Martin avec les référentiels CVE et ATT&K de MITRE, mais si vous le jugez vraiment pertinent vous pouvez adapter ces outils ou en utiliser d'autres. Vous évaluerez le risque d'une telle attaque pour l'entreprise.

De plus, vous devrez émettre un minimum de deux recommandations pour améliorer la sécurité du système d'information afin de se prémunir d'une attaque comme celle que vous avez décrite. Ces recommandations ne devront pas être génériques, mais adaptées au système d'information de l'entreprise Gamma.

3 Remarques

Même si vous êtes bien entendu encouragés à faire preuve de créativité, votre présentation devra avant tout être claire et cohérente. Privilégiez donc des réponses simples que vous saurez expliquer, plutôt que des solutions complexes que personne ne comprendra.

Pour les besoins de l'exercice, vous pouvez partir du principe que toutes les conditions nécessaires à l'exploitation de la vulnérabilité dans le SI sont réunies: par exemple, si l'exploitation d'une vulnérabilité implique qu'un flux soit ouvert sur un pare-feu, faites comme s'il n'y avait pas de pare-feu. De même, si par exemple la vulnérabilité implique que le composant impacté

communique avec un certain type de protocole, ou prenne un certain type de fichier en entrée, partez du principe que ce protocole ou ce type de fichier sont bien utilisés.

Enfin, toutes vos réponses doivent impérativement être justifiées, et toute technique ou technologie mentionnée doit être définie.

4 Support

Pour aider à la compréhension de votre présentation, il vous sera demandé de projeter un support; le format (PowerPoint, PDF, etc), le contenu et le nombre de diapositives sont libres, du moment que le rendu est soigné. La seule contrainte est que le support doit servir à appuyer votre propos, et non l'inverse: le texte doit être réduit au minimum, les schémas doivent rester simples.

L'exercice devra être réalisé sans notes et en lisant le moins possible ce qui est projeté.

5 Architecture du système d'information

Dans l'entreprise, il y a trois types d'utilisateurs: les employés, les informaticiens et les managers. Tous les utilisateurs sont pourvus de postes de travail fonctionnant sous Windows 10 Version 1803, connectés à Internet, et disposant d'Adobe Reader DC 2017.009.20044 et d'Outlook 2016 Build 16.0.4599.9999.

Le site vitrine de l'entreprise est réalisé avec la version 2.3.32 du framework Apache Struts, et est hébergé sur le serveur *gammaweb*.

Les profils client, données de suivi, détails de campagne et toutes les autres données liées au métier publicitaire sont stockés dans des bases MongoDB version 4.0.8 sur serveur nommé *mgosrv*. Un webservice nommé *GammaPublisWS* a été développé en interne en Python 3.6.8 avec le framwork Django 2.2.3, et hébergé sur un serveur dédié nommé *publisws* permet aux utilisateurs de joindre et d'interroger cette base de données.

Les fichiers utilisés dans les campagnes publicitaires, c'est à dire les photos et vidéos, sont eux hébergés sur un stockage NFS sur le serveur *pubnfs*.

Enfin, les données liées au fonctionnement interne de l'entreprise, comme les résultats financiers et les informations RH, sont stockées sur des bases de données SQL Server 2014 version 12.0.2000.8 sur un serveur nommé *sqlsrv*. Cette fois-ci, c'est un programme nommé *GammaManagementWS*, développé en interne en C# avec ASP.NET, hébergé sur le serveur *managws*, qui permet aux utilisateurs d'interagir avec ces bases.

Les serveurs *gammaweb*, *mgosrv*, *publisws* et *pubnfs* fonctionnent avec RHEL 7.4, sur lequel tourne entre autres un démon OpenSSH utilisant libSSH 0.7.5. Les serveurs *sqlsrv* et *managws*, quant à eux, tournent sous Windows Server 2016 version 1803, avec un service RDP version 10.0, et une version du framework .NET 4.7.